مستند جامع پیاده‌سازی بک‌اند و قرارداد وب‌سرویس‌ها (API)

ویژه پیاده‌سازی کامل بک‌اند آکادمی تخصصی «آواز آموز» (آموزش مداحی و صداسازی)

نسخه سند: ۲.۰ (جامع) | مخاطب: تیم / توسعه‌دهنده بک‌اند | وضعیت فرانت‌اند: بیلد شده و آماده استقرار (Production Ready)

فرمت تبادل داده: RESTful JSON

۱. مقدمه، معماری کلی و نحوه اتصال فرانت‌اند

این سند فنی به عنوان دستورالعمل قطعی و قرارداد رسمی وب‌سرویس‌ها (API Contract) میان فرانت‌اند بیلد شده آکادمی **«آواز آموز»** و سیستم بک‌اند تهیه گردیده است. فرانت‌اند این پروژه با React 19، Vite و Tailwind CSS به صورت یک اپلیکیشن تک‌صفحه‌ای (SPA) کاملاً مستقل (Decoupled) توسعه یافته است. بک‌اند این سامانه می‌تواند با هر فریم‌ورک استانداردی نظیر **Node.js، Go / Python، Laravel / PHP یا Django / .NET** از ابتدا پیاده‌سازی شود، مشروط بر آنکه تمامی اندپوینت‌ها، ساختارهای JSON ورودی و خروجی، کدهای وضعیت HTTP و الزامات امنیتی تشریح‌شده در این مستند دقیقاً رعایت گردند.

نحوه اتصال داینامیک فرانت‌اند به آدرس بک‌اند شما:

در بسته فرانت‌اند، فایلی به نام `config.js` در ریشه قرار دارد. فرانت‌اند در زمان اجرا ابتدا آدرس API را از این فایل می‌خواند. توسعه‌دهنده بدون نیاز به ری‌بیلد کردن پروژه، تنها با قرار دادن آدرس دامنه بک‌اند در این فایل می‌تواند ارتباط را برقرار کند:

```
// public/config.js یا dist/config.js
window.__API_URL__ = "https://api.yourdomain.ir/api";
```

در صورتی که این مقدار خالی باشد، فرانت‌اند به صورت پیش‌فرض درخواست‌ها را به آدرس نسبی `/api` ارسال خواهد کرد.

تنظیمات ضروری CORS (Cross-Origin Resource Sharing)

بک‌اند شما باید هدرهای CORS زیر را برای تمامی درخواست‌ها (به ویژه درخواست‌های Preflight متد `OPTIONS`) بازگرداند:

- `Access-Control-Allow-Origin` : آدرس دامنه فرانت‌اند (مثلاً `https://avazamouz.ir`) یا `*` در فاز توسعه).
- `Access-Control-Allow-Methods` : `GET, POST, PUT, PATCH, DELETE, OPTIONS`
- `Access-Control-Allow-Headers` : `Authorization, Content-Type, Accept, X-Requested-With`
- `Access-Control-Allow-Credentials` : `true`

۲. معماری حیاتی امنیت ویدیوها و جلوگیری از دانلود غیرمجاز (DRM & Anti-Download)

قانون طلایی امنیت فایل‌های دوره:

هرگز و تحت هیچ شرایطی نباید آدرس مستقیم و فایل فیزیکی استاتیک MP4 به کاربر بازگردانده شود! ارسال آدرس مستقیم `.mp4` باعث می‌شود هر افزونه دانلودر مرورگر (مانند IDM) با یک کلیک فایل را سرقت کند.

فرانت‌اند آکادمی آواز آموز مجهز به پلیر فوق‌امنیتی اختصاصی **(SecureVideoPlayer)** بر پایه کتابخانه `hls.js` است. این پلیر لایه‌های امنیتی زیر را در کلاینت پیاده کرده است:

- مسدودسازی کلیک‌راست و منوی contextmenu مرورگر روی ویدیو.
- توقف خودکار ویدیو به محض باز شدن DevTools یا فشردن کلیدهای F12، Inspect Element و Ctrl+U.
- توقف خودکار ویدیو هنگام تغییر تب مرورگر یا فعال شدن ابزارهای فیلم‌برداری از صفحه (Window Blur & Visibility API).
- پوشش نامرئی (Shield Overlay) جهت عقیم‌سازی کلیک دانلودرهای افزونه‌ای مرورگر.
- پخش استریم‌های رمزنگاری شده HLS AES-128 همراه با تزریق خودکار توکن کاربر به ریکوئست‌های سگمنت و کلید.

زنجیره رمزنگاری HLS + AES-128 در بک‌اند (وظیفه سرور):

1. **تبدیل ویدیوها به سگمنت‌های رمزنگاری شده HLS:** ویدیوهای دوره‌ها باید توسط ابزار `ffmpeg` به قطعات کوچک چند ثانیه‌ای (سگمنت‌های `.ts`) تقسیم و با کلید ۱۶ بایتی تصادفی AES-128 رمزنگاری شوند:

```
ffmpeg -i lesson.mp4 -c:v h264 -c:a aac -hls_time 6 -hls_playlist_type vod -hls_key_info_file key_info.t
```

2. **محافظت از فایل کلید رمزگشایی (Decryption Key Gate):** در فایل `key_info.txt` آدرس دریافت کلید به اندپوینت اختصاصی بک‌اند متصل می‌شود:

```
https://api.yourdomain.ir/api/courses/stream-key/?token=SECURE_SIGNED_TOKEN
```

3. **منطق تایید دسترسی در اندپوینت کلید (`/stream-key/`):** سرور تنها و تنها زمانی مقدار باینری ۱۶ بایتی کلید رمزگشایی را صادر می‌کند که:
   - کاربر وارد حساب خود شده باشد (Authorization Token در هدر یا پارامتر Query ارسالی از `hls.js`).
   - کاربر در دیتابیس، دوره مورد نظر را خریده باشد (`is_enrolled == true`) یا جلسه دارای فلگ `is_free_preview == true` باشد.
   - توکن دارای امضای زمانی معتبر و منقضی‌نشده باشد (مانند توکن‌های HMAC با انقضای ۳۰ دقیقه).

   در غیر این صورت، سرور بلافاصله خطای **Forbidden 403** بازمی‌گرداند. بدین ترتیب حتی اگر شخصی فایل `.m3u8` یا سگمنت‌های `.ts` را ذخیره کند، فایل‌ها به صورت دیتای غیرقابل پخش و رمزنگاری‌شده خواهند بود.

4. **عدم افشای فیلد `video_url` برای جلسات قفل‌شده:** در اندپوینت دریافت جزئیات دوره (`GET /courses/{slug}/`)، برای جلساتی که کاربر به آن‌ها دسترسی ندارد، فیلد `video_url` باید به صورت `null` یا رشته خالی باشد. آدرس مانیفست استریم فقط و فقط در اندپوینت `GET /courses/{slug}/lessons/{id}/` پس از راستی‌آزمایی دسترسی دانشجو برگردانده می‌شود.

۳. احراز هویت، ورود دوگانه (رمز عبور / پیامک OTP) و مدیریت کاربران

فرانت‌اند سیستم ورود هوشمندی دارد که به صورت پیش‌فرض **فرم نام کاربری/شماره + رمز عبور** را نمایش می‌دهد و در صورت نیاز کاربر، تب ورود با **کد تایید پیامکی (OTP)** در اختیار او قرار می‌گیرد.

هدرهای احراز هویت قابل قبول:

کلاینت به صورت خودکار توکن احراز هویت را در تمامی ریکوئست‌های محافظت‌شده ارسال می‌کند. بک‌اند شما می‌تواند از هر یک از دو استاندارد زیر استفاده کند (فرانت‌اند هر دو را می‌شناسد):

- `Authorization: Bearer <JWT_TOKEN>` (معماری JWT)
- `Authorization: Token <DATABASE_TOKEN_KEY>` (معماری توکن جنگو / لاراول)

۱. ورود با رمز عبور (Password Login)

`POST` `/api/accounts/login/` | عمومی

کاربر می‌تواند در فیلد شناسه، **نام کاربری** یا **شماره موبایل** خود را وارد کند.

```
// Request Body
{
  "identifier": "09121112233",  // فرانت‌اند فیلدهای زیر را نیز همزمان ارسال می‌کند
  "username": "09121112233",
  "phone_number": "09121112233",
  "password": "user_password_123"
}

// Response (HTTP 200 OK)
{
  "token": "9944b09199c62bcf9418ad846dd0e4bbdfc6ee4b", // یا فیلد "access" در JWT
  "user": {
    "id": 1,
    "username": "student",
    "phone_number": "09121112233",
    "full_name": "محمد رضایی",
    "email": "m.rezaei@example.com",
    "is_staff": false
  }
}
```

۲. ارسال کد تایید پیامکی (Send OTP)

`POST` `/api/accounts/send-otp/` | عمومی

```
// Request Body
{
  "phone_number": "09121112233" // فیلدهای mobile و phone فرانت‌اند را نیز ارسال می‌کند
}

// Response (HTTP 200 OK)
{
  "success": true,
  "message": "کد تایید با موفقیت پیامک شد.",
  "dev_code": "58214" // فقط در محیط لوکال و DEBUG نشود ارسال در پروداکشن مجاز است،
}
```

الزامات امنیتی درگاه پیامک OTP در بک‌اند:

- **محدودیت نرخ (Rate Limiting):** برای هر شماره موبایل، حداکثر یک درخواست در هر ۲ دقیقه (۱۲۰ ثانیه) مجاز است. در صورت درخواست زودهنگام خطای 429 بازگردانید.
- **طول و انقضا:** کد باید ۵ یا ۶ رقم تصادفی بوده و پس از ۱۲۰ ثانیه منقضی شود.
- **محافظت Brute-Force:** پس از ۳ تلاش ناموفق برای ورود کد، کد OTP باید منقضی شده و کاربر ملزم به درخواست کد جدید باشد.

۳. تایید کد پیامکی و ورود / ثبت‌نام خودکار (Verify OTP)

`POST` `/api/accounts/verify-otp/` | عمومی

اگر کاربر قبلاً با این شماره ثبت شده بود وارد سیستم شود؛ اگر شماره جدید بود، یک کاربر جدید به صورت خودکار ایجاد و توکن او صادر شود.

```
// Request Body
{
  "phone_number": "09121112233",
  "code": "58214",
  "full_name": "اختیاری"
}

// Response (HTTP 200 OK)
{
  "token": "jwt_or_database_token_string",
  "user": {
    "id": 1,
    "username": "09121112233",
    "phone_number": "09121112233",
    "full_name": "کاربر آواز آموز",
    "is_staff": false
  }
}
```

۴. دریافت و ویرایش اطلاعات کاربر جاری (Current User Profile)

`GET` `PUT` `/api/accounts/me/` | نیازمند لاگین

جهت بررسی زنده معتبر بودن توکن در هنگام لود صفحات و همچنین ویرایش نام و ایمیل کاربر در پنل کاربری.

```
// GET /api/accounts/me/ -> Response (HTTP 200 OK)
{
  "id": 1,
  "username": "student",
  "phone_number": "09121112233",
  "full_name": "محمد رضایی",
  "email": "m.rezaei@example.com",
  "is_staff": false,
  "date_joined": "2026-03-15T10:00:00Z"
}

// PUT /api/accounts/me/ -> Request Body (جهت به‌روزرسانی پروفایل)
{
  "full_name": "محمد رضایی اصل",
  "email": "new.email@example.com"
}
```

۴. محتوای داینامیک، تنظیمات برندینگ، لوگو و اینماد

تمامی متون هیرو، بنر مزایا، اطلاعات تماس، نماد اعتماد الکترونیکی (اینماد)، اطلاعات فوتر و سوالات متداول به شکل داینامیک از بک‌اند خوانده می‌شوند. کلاینت برای جلوگیری از ترافیک اضافی، این مقادیر را در یک کانتکست کلاینتی کش می‌کند.

تنظیمات اصلی سایت (Site Settings)

`GET` `/api/core/settings/` | عمومی

```
// Response (HTTP 200 OK)
{
  "site_title": "آواز آموز",
  "logo_url": "https://api.yourdomain.ir/media/site/logo.png", // ارسال شود null اگر عکسی آپلود نشده باشد مقدار
  "hero_badge": "نخستین آکادمی تخصصی آموزش مداحی و صداسازی مذهبی",
  "hero_title": "آموزش اصولی مداحی، فن بیان و صداسازی با اساتید برجسته",
  "hero_subtitle": "ورش و تقویت حنجره تا تسلط بر دستگاه‌های آوازی، مقتل‌خوانی، نوحه‌سرایی و مجلس‌داری را به صورت گام‌به‌گام بیاموزید
  "features_badge": "چرا آکادمی آواز آموز؟",
  "features_title": "تربیت ذاکران و مداحان اهل‌بیت با اصیل‌ترین متدهای صوتی و معرفتی",
  "features_subtitle": "ب با اصول صداسازی علمی، لحن‌شناسی، ادعیه‌خوانی و آداب نوکری به همراه رفع اشکال و تمرین‌های صوتی هدفمند
  "contact_phone": "۰۲۱-۹۱۰۰۰۰۰۰",
  "contact_email": "info@avazamouz.ir",
  "telegram_url": "https://t.me/avazamouz",
  "instagram_url": "https://instagram.com/avazamouz",
  "footer_about": "است. رسالت ما توانمندسازی علاقه‌مندان به ستایشگری اهل‌بیت (ع) با تکیه بر علم صداسازی و اصالت‌های سنتی است
  "enamad_html": "<a referrerpolicy='origin' target='_blank' href='https://trustseal.enamad.ir/...'><img sr
}
```

> **نکته مهم در رابطه با لوگو:**
> اگر در فیلد `logo_url` مقدار `null` ارسال شود یا تصویری آپلود نشده باشد، فرانت‌اند به صورت خودکار و یکپارچه، نشان وکتور طراحی‌شده آکادمی آواز آموز را نمایش می‌دهد. به محض اینکه ادمین تصویری در بک‌اند آپلود کند، تصویر او در تمام سایت جایگزین خواهد شد.

سوالات متداول (FAQs)

`GET` `/api/core/faqs/` | عمومی

```
// Response (HTTP 200 OK)
[
  {
    "id": 1,
    "question": "آیا برای شرکت در دوره‌ها نیاز به پیش‌زمینه خوانندگی یا مداحی داریم؟",
    "answer": "ی سطح مقدماتی از اصول پایه صداسازی، بهداشت حنجره و تنفس دیافراگمی آغاز می‌شوند و برای کلیه علاقه‌مندان مناسب است
    "order": 1
  },
  {
    "id": 2,
    "question": "نحوه ارسال تمرین‌های صوتی و رفع اشکال با اساتید چگونه است؟",
    "answer": "پس از مشاهده جلسات، فایل صوتی تمرین خود را در پنل یا پیام‌رسان پشتیبانی ارسال کرده و بازخورد اختصاصی دریافت نمایند
    "order": 2
  }
]
```

۵. مدیریت دوره‌ها، دسته‌بندی‌ها، سرفصل‌ها و جلسات آموزشی

۱. دسته‌بندی‌ها (Categories)

`GET` `/api/courses/categories/` | عمومی

```
// Response (HTTP 200 OK)
[
  {
    "id": 1,
    "title": "صداسازی و پرورش حنجره",
    "slug": "vocal-training",
    "icon": "Mic", // یکی از آیکون‌های استاندارد: Mic, Music, BookOpen, Volume2, Heart, Radio
    "description": "تقویت عضلات تنفسی، انعطاف تارهای صوتی، پرده‌های صوتی و رفع گرفتگی صدا",
    "courses_count": 3
  },
  {
    "id": 2,
    "title": "دستگاه‌ها و نغمات آوازی",
    "slug": "maqamat-radif",
    "icon": "Music",
    "description": "آموزش ردیف آوازی و الحان سنتی شامل شور، دشتی، بیات اصفهان، همایون و شوشتری در مداحی",
    "courses_count": 2
  }
]
```

۲. بانک دوره‌ها (Courses Catalog & Search)

`GET` `/api/courses/` | عمومی (با احتساب توکن جهت وضعیت خرید)

پارامترهای قابل قبول در Query String:

- `category=slug` : فیلتر بر اساس اسلاگ دسته‌بندی
- `level=all|beginner|intermediate|advanced` : فیلتر سطح دوره
- `price=free|paid` : فیلتر رایگان یا پولی
- `جستجو=q` : جستجو در عنوان، نام استاد، دستگاه آوازی یا خلاصه دوره

```
// Response (HTTP 200 OK) - لیستی از دوره‌ها
[
  {
    "id": 1,
    "title": "دوره جامع صداسازی تخصصی مداحی و پرورش حنجره",
    "slug": "mastering-maddahi-vocals",
    "category": {
      "id": 1,
      "title": "صداسازی و پرورش حنجره",
      "slug": "vocal-training"
    },
    "short_description": "م تنفس صحیح دیافراگمی، افزایش دانگ و حجم صدا، تحریرهای سنتی و اوج‌خوانی بدون آسیب به تارهای صوتی
    "instructor_name": "استاد حاج مرتضی طاهری",
    "instructor_title": "مدرس عالی صداسازی و ردیف‌های آوازی ستایشگری",
    "duration": "ساعت آموزش ویدیویی ۱۸",
    "lessons_count": 24,
    "rating": 4.9,
    "students_count": 1420,
    "price": 1490000,
    "discount_price": 980000,
    "final_price": 980000,
    "is_free": false,
    "is_sales_enabled": true,
    "cover_image_url": "https://api.yourdomain.ir/media/courses/cover-1.jpg",
    "level": "intermediate", // all, beginner, intermediate, advanced
    "is_enrolled": false // ارسال شود true اگر کاربر لاگین باشد و دوره را خریده باشد
  }
]
```

۳. جزئیات کامل یک دوره و سرفصل‌ها (Course Detail)

`GET` `/api/courses/{slug}/` | عمومی

این اندپوینت سرفصل‌ها (Sections) و جلسات (Lessons) زیرمجموعه را بازمی‌گرداند.

```
// Response (HTTP 200 OK)
{
  "id": 1,
  "title": "دوره جامع صداسازی تخصصی مداحی و پرورش حنجره",
  "slug": "mastering-maddahi-vocals",
  "short_description": "آموزش گام‌به‌گام تنفس صحیح دیافراگمی...",
  "description": "متن کامل و جامع توضیحات دوره همراه با معرفی اساتید و ساختار جلسات...",
  "what_you_will_learn": "تکنیک‌های تنفس دیافراگمی و تسلط بر پرده‌های صوتی
اجرای تحریرهای مقطع و پیوسته سنتی
مدیریت حنجره در مجالس طولانی بدون احساس خستگی",
  "instructor_name": "استاد حاج مرتضی طاهری",
  "instructor_title": "مدرس عالی صداسازی و ردیف‌های آوازی ستایشگری",
  "instructor_bio": "بیش از ۳۰ سال سابقه تدریس صداسازی و نغمه‌خوانی آیینی...",
  "duration": "۱۸ ساعت",
  "lessons_count": 24,
  "rating": 4.9,
  "students_count": 1420,
  "price": 1490000,
  "discount_price": 980000,
  "final_price": 980000,
  "is_free": false,
  "is_sales_enabled": true,
  "cover_image_url": "https://api.yourdomain.ir/media/courses/cover-1.jpg",
  "intro_video_url": "https://api.yourdomain.ir/media/hls/intro/master.m3u8", // ویدیوی معرفی رایگان
  "level": "intermediate",
  "is_enrolled": false,
  "sections": [
    {
      "id": 10,
      "title": "فصل اول: فیزیولوژی حنجره و مبانی تنفس دیافراگمی",
      "order": 1,
      "lessons": [
        {
          "id": 101,
          "title": "آشنایی با مکانیزم حنجره و بهداشت صوت در مجالس",
          "order": 1,
          "duration": "۱۸:۴۵",
          "is_free_preview": true, // قابل تماشای رایگان توسط همه
          "has_access": true,
          "video_url": "", // در این اندپوینت عمومی نیازی به پر کردن لینک ویدیو نیست
          "description": "نکات اولیه حفظ سلامت حنجره..."
        },
        {
          "id": 102,
          "title": "تمرینات عملی تنفس دیافراگمی و حبس نفس",
          "order": 2,
          "duration": "۲۴:۱۰",
          "is_free_preview": false,
          "has_access": false
        }
      ]
    }
  ]
}
```

۶. پخش ویدیو در پلیر اختصاصی (Lesson Watch Player)

`GET` `/api/courses/{slug}/lessons/{lesson_id}/` | محافظت‌شده

هنگامی که کاربر وارد اتاق پخش جلسه (صفحه `/course/:slug/watch/:lessonId`) می‌شود، فرانت‌اند این اندپوینت را فراخوانی می‌کند.

بررسی سطح دسترسی (Authorization Gate):

سرور باید وضعیت کاربر را بررسی کند:

- اگر `is_free_preview == true` باشد: بدون نیاز به ثبت‌نام دوره، لینک استریم تولید و ارسال شود.
- اگر جلسه پولی باشد: سرور باید بررسی کند آیا کاربر در این دوره ثبت‌نام کرده است یا خیر. در صورت عدم ثبت‌نام، حتماً خطای **Forbidden 403** با پیام فارسی بازگردانده شود:

```
// Response (HTTP 403 Forbidden)
{
  "error": "برای تماشای این جلسه آموزشی، ابتدا در دوره ثبت‌نام فرمایید."
}
```

در صورت تایید دسترسی، پاسخ با ساختار زیر ارسال می‌گردد:

```
// Response (HTTP 200 OK)
{
  "id": 101,
  "title": "آشنایی با مکانیزم حنجره و بهداشت صوت در مجالس",
  "order": 1,
  "duration": "۱۸:۴۵",
  "description": "در این درس با آناتومی تارهای صوتی و تمرینات جلوگیری از خستگی حنجره آشنا می‌شوید...",
  "video_url": "https://api.yourdomain.ir/media/hls/lesson-101/master.m3u8?token=SIGNED_EXPIRING_HMAC_TOKEN
  "attachment_url": "https://api.yourdomain.ir/media/attachments/lesson-101-notes.pdf", // (جزوه یا صوت تمرین
  "is_free_preview": true,
  "prev_lesson_id": null,
  "next_lesson_id": 102,
  "course_title": "دوره جامع صداسازی تخصصی مداحی و پرورش حنجره",
  "course_slug": "mastering-maddahi-vocals"
}
```

۷. فرآیند خرید، صدور فاکتور و اتصال به درگاه پرداخت بانکی (Checkout)

۱. شروع فرآیند خرید (Checkout)

`POST` `/api/orders/checkout/` | نیازمند لاگین

```
// Request Body
{
  "course_id": 1
}
```

حالت اول: دوره رایگان یا مبلغ نهایی صفر تومان

اگر دوره رایگان باشد، نباید به درگاه پرداخت متصل شود؛ بلافاصله رکورد دسترسی (Enrollment) برای دانشجو ایجاد شده و پاسخ موفق بازگردانده می‌شود:

```
// Response (HTTP 200 OK)
{
  "success": true,
  "status": "completed",
  "tracking_code": "ORD-FREE-74892",
  "message": "ثبت‌نام شما در دوره رایگان با موفقیت انجام شد."
}
```

حالت دوم: دوره پولی و نیازمند پرداخت بانکی

یک رکورد سفارش با وضعیت `pending` ثبت شده و کاربر با آدرس دریافتی به درگاه رسمی متصل می‌شود:

```
// Response (HTTP 200 OK)
{
  "success": true,
  "status": "pending",
  "tracking_code": "ORD-140307-8821",
  "payment_url": "https://payment.zarinpal.com/pg/StartPay/0000000000000000000000000000000000000000"
}
```

۲. کال‌بک درگاه بانکی و اعتبارسنجی تراکنش (Payment Verification)

هنگامی که مشتری در صفحه شاپرک پرداخت را انجام داد، بانک کاربر را به آدرس بازگشت (Callback URL) بک‌اند شما هدایت می‌کند.

1. **استعلام قطعی از وب‌سرویس بانک:** بک‌اند حتماً باید متد `PaymentVerification` را با مرجع پرداخت فراخوانی کند. هرگز به متغیرهای ارسالی در Query String اعتماد نکنید.
2. **ثبت دسترسی دوره در صورت موفقیت:** وضعیت سفارش به `completed` تغییر کرده و دوره به لیست دوره‌های فعال کاربر اضافه می‌شود.
3. **ریدایرکت کاربر به پنل فرانت‌اند:** بک‌اند باید مرورگر کاربر را با آدرس و پارامترهای زیر به فرانت‌اند هدایت کند:

```
// در صورت موفقیت:
Location: https://avazamouz.ir/dashboard?payment=success&tracking=ORD-140307-8821&course=mastering-madda

// در صورت انصراف یا خطا:
Location: https://avazamouz.ir/dashboard?payment=failed&tracking=ORD-140307-8821
```

۳. دوره‌های خریداری‌شده من (My Courses)

`GET` `/api/orders/my-courses/` (یا `/api/courses/my-courses/`) | نیازمند لاگین

```
// Response (HTTP 200 OK)
[
  {
    "id": 12,
    "enrolled_at": "2026-03-20T14:30:00Z",
    "course": {
      "id": 1,
      "title": "دوره جامع صداسازی تخصصی مداحی و پرورش حنجره",
      "slug": "mastering-maddahi-vocals",
      "cover_image_url": "https://api.yourdomain.ir/media/courses/cover-1.jpg",
      "duration": "۱۸ ساعت",
      "lessons_count": 24,
      "instructor_name": "استاد حاج مرتضی طاهری"
    }
  }
]
```

۴. تاریخچه سفارش‌ها و فاکتورها (My Orders)

`GET` `/api/orders/my-orders/` | نیازمند لاگین

```
// Response (HTTP 200 OK)
[
  {
    "id": 48,
    "tracking_code": "ORD-140307-8821",
    "course_title": "دوره جامع صداسازی تخصصی مداحی و پرورش حنجره",
    "course_slug": "mastering-maddahi-vocals",
    "amount": 980000,
    "status": "completed", // completed, pending, canceled
    "created_at": "2026-03-20T14:28:10Z"
  }
]
```

۸. چک‌لیست جامع امنیتی سمت سرور (Backend Security Checklist)

حوزه امنیتی	تهدید یا ریسک بالقوه	دستورالعمل اجرایی در بک‌اند
محافظت از فایل‌های ویدیویی	سرقت مستقیم دوره‌ها با نرم‌افزارهای دانلود منیجر یا اسکریپت‌های وب‌اسکرپینگ	سگمنت‌بندی HLS + رمزنگاری AES-128 + گیت کنترل دسترسی بر روی اندپوینت صدور کلید رمزگشایی با Signed Token منقضی‌شونده.
کنترل دسترسی اشیاء (IDOR)	دسترسی غیرمجاز به فاکتورها، دوره‌ها یا ویرایش مشخصات سایر کاربران با حدس زدن ID	بررسی مالکیت رکورد در تمام اندپوینت‌ها؛ کاربر تنها باید به رکوردهایی که `user_id == request.user.id` دارند دسترسی داشته باشد.
سوءاستفاده از پنل پیامک (SMS Flooding)	ارسال مکرر پیامک توسط ربات‌ها و ایجاد هزینه‌های سرسام‌آور شارژ پیامک	اعمال Rate Limit سخت‌گیرانه (۱ پیامک در هر ۲ دقیقه برای هر شماره تلفن و حداکثر ۵ درخواست در ساعت از یک IP).
تایید تراکنش مالی (Payment Spoofing)	اعلام موفقیت ساختگی پرداخت با دستکاری مقادیر بازگشتی مرورگر بدون واریز وجه	استعلام مستقیم از API درگاه با Secret Key سمت سرور و ذخیره کد رهگیری بانک قبل از فعال‌سازی دوره برای کاربر.
تزریق کد و کوئری (SQL Injection & XSS)	دستکاری دیتابیس یا اجرای اسکریپت مخرب در متن فیلدها	استفاده مطلق از ORM استاندارد، پارامترایز کردن کوئری‌ها و Escape کردن فیلدهای ورودی قبل از ذخیره.
ذخیره‌سازی رمزهای عبور	لو رفتن پسوردهای کاربران در صورت نشت احتمالی دیتابیس	استفاده از الگوریتم‌های استاندارد نظیر Argon2 یا PBKDF2 با فاکتور کاری (Work Factor) و Salt تصادفی منحصر به فرد.
مدیریت پیام‌های خطا (Error Handling)	افشای ساختار دیتابیس و فریم‌ورک از طریق متن Traceback	عدم نمایش Stack Trace در حالت پروداکشن و بازگرداندن پاسخ‌های استاندارد JSON با ساختار `{"error": "پیام خوانا"}` .

خلاصه فایل‌های بسته‌بندی فرانت‌اند تحویل‌شده:

- **`avazamouz-frontend-dist.zip`** : پکیج بیلد نهایی و آماده پروداکشن (شامل `index.html` ، `assets/` ، `config.js` ، `.htaccess`) جهت بارگذاری در هاست لینوکسی، Apache، Nginx یا هاست‌های ابری cPanel.
- **`avazamouz-frontend-source.zip`** : سورس‌کد کامل پروژه فرانت‌اند بر پایه React 19 + TypeScript جهت اعمال تغییرات احتمالی بعدی.
- **`avazamouz-backend-specification.pdf`** : نسخه PDF همین مستند فنی جهت تحویل به توسعه‌دهنده بک‌اند.

آکادمی تخصصی آموزش مداحی و صداسازی «آواز آموز» • تمامی حقوق فنی و آموزشی محفوظ است.